Deliverable 1:Threat Modelling

Encrypted Smart Complaint Management System

Made by:

M. Maisam Raza Reg no:2023463

Abdullah Reg no:2023033

Shaheem Reg no:2023507

Presented to: Dr. Zubair Ahmed

1. Introduction to Threat Modeling

Threat modeling is a systematic process used in cybersecurity to identify, enumerate and prioritize potential threats to an information system. It combines architectural analysis, attacker-centric reasoning, and risk assessment in order to produce actionable mitigations that can be integrated into system design and operation. In software engineering curricula and professional practice alike, threat modeling is essential because it allows design teams to anticipate attack vectors, reduce attack surface, and make informed trade-offs between security, usability, and cost.

Conducting threat modeling early in the Software Development Lifecycle (SDLC) embeds security into the system's architecture rather than retrofitting controls after implementation. Early identification of vulnerabilities reduces remediation cost, prevents insecure design choices from becoming entrenched, and informs testing and assurance activities (e.g., code review, penetration testing, and formal verification targets). A rigorous threat-modeling process also supports compliance, auditability, and documentation that are required in academic and operational contexts.

This report uses the STRIDE threat modeling framework to structure and communicate threats against the Encrypted Smart Complaint Management System. STRIDE classifies threats into six categories: Spoofing (identity impersonation), Tampering (unauthorized modification of data), Repudiation (denial of actions or transactions), Information Disclosure (unauthorized access to confidential information), Denial of Service (disruption of service availability), and Elevation of Privilege (unauthorized privilege escalation). Each category guides the analysis of attack scenarios and the selection of mitigations.

STRIDE Categories (brief)

- Spoofing: Unauthorized actors use stolen or forged credentials to assume another identity.
- Tampering: Adversaries alter data in transit or at rest to distort system state or outcomes.
- Repudiation: Actors perform actions and later deny responsibility, often in absence of adequate logging or non-repudiation mechanisms.
- Information Disclosure: Sensitive data is exposed to unauthorized parties, either through access control failures or cryptographic weaknesses.
- Denial of Service: Attackers degrade or interrupt system availability, preventing legitimate use.
- Elevation of Privilege: Users or processes gain higher privileges than intended, enabling unauthorized actions.

2. System Architecture Overview

The Encrypted Smart Complaint Management System adopts a three-tier architecture: Presentation Layer, Application Layer, and Data Layer. This separation of concerns facilitates security hardening at discrete trust boundaries and simplifies the application of principle-of-least-privilege controls.

Presentation Layer (Web Interface)

The presentation layer provides the user interface consumed by students, maintenance staff, and administrators via standard web browsers. Responsibilities include rendering authenticated user views, accepting complaint submissions, displaying complaint status, and exposing administrative controls for assignment, escalation, and reporting. This layer performs client-side validation and user experience tasks, and it communicates with the application layer exclusively over TLS-encrypted channels (HTTPS). It also enforces secure cookie attributes (Secure, HttpOnly, SameSite) and implements content security policy (CSP) headers to reduce the risk of client-side script injection.

Application Layer (Business Logic)

The application layer implements core functionality: user authentication and session management, role-based access control (RBAC), complaint lifecycle processing, encryption and decryption logic for complaint content, input validation, and interaction orchestration with the data layer. Authentication uses strong password hashing and multi-factor authentication where appropriate; RBAC enforces least privilege by segregating student, staff, and administrator capabilities. The application performs server-side validation, sanitisation, and output encoding to prevent injection and cross-site scripting. Encryption operations for complaint data are handled here using well-vetted cryptographic libraries and secure key management practices.

Data Layer (Database)

The data layer persists complaint records, metadata, and user account information in a relational database. Sensitive complaint payloads are encrypted at rest using AES-256 with authenticated encryption (e.g., AES-GCM) while non-sensitive metadata is stored in plaintext as required for indexing and workflow. Database access is restricted through parameterized queries (prepared statements), minimal service accounts, and fine-grained permissions. Backup media is encrypted and access to keys is audited. Data integrity is preserved by transactional semantics and cryptographic integrity checks where applicable.

3. System Architecture Diagram

Users (Students / Staff / Admin)
↓
Web Browser / Web Interface
(Presentation Layer)
↓ HTTPS / TLS
Application Server

(Authentication, RBAC, Complaint Processing, Encryption)
(Application Layer)
↓ Secure Queries
Database Server
(Encrypted Complaint Data)
(Data Layer)

4. STRIDE Threat Modeling Analysis

STRIDE Category	**Threat Description**	**Example Attack Scenario**	**Security Impact**	**Mitigation Strategy**
Spoofing	Impersonation of legitimate users using stolen or forged credentials.	Attacker obtains a student's credentials via phishing and submits or modifies complaints under that identity.	Unauthorized access to complaint workflows, privacy breaches, fraudulent actions.	Enforce MFA, bcrypt password hashing, account lockout on repeated failures, robust phishing-resistant training, and session binding. Log authentication events.
Tampering	Unauthorized modification of complaint records in transit or at rest.	Attacker with database access flips resolution status or edits complaint details to hide incidents.	Loss of data integrity; misrouting or suppression of remediation actions; reputational harm.	Use TLS in transit, AES-256 authenticated encryption for data at rest, database role separation, parameterized queries, cryptographic checksums, and tamper-evident audit logs.
Repudiation	Users deny submitting or altering complaints in absence of reliable logs.	Administrator rejects liability claiming a complaint was never assigned because no proof exists.	Challenges in dispute resolution and lack of accountability.	Implement secure, tamper-evident audit logging with timestamps and user identifiers, digital signatures for critical actions, and immutable log storage or append-only mechanisms.
Information Disclosure	Unauthorized exposure of confidential complaint content or PII.	Exploitation of an injection vulnerability reveals plaintext complaint content or escalated	Breach of confidentiality, regulatory violations, and harm to individuals.	Encrypt complaint content with AES-256, apply strict RBAC, sanitize inputs, employ least privilege for database accounts, and

STRIDE Category	Threat Description	Example Attack Scenario	Security Impact	Mitigation Strategy
		privileges read sensitive fields.		perform regular access reviews.
Denial of Service	Service disruption preventing complaint submission or status access.	Attackers flood the application or resource exhaustion on the database causing outage.	Reduced availability of complaint submission and tracking; operational disruption.	Rate limiting, web application firewall (WAF), resilient infrastructure (load balancing, autoscaling), circuit breakers, and DDoS protection services.
Elevation of Privilege	Unauthorized escalation from student to administrative privileges.	Exploitation of insecure direct object references or flawed authorization checks grants admin access.	Full compromise of complaint management, data exfiltration, and unauthorized modifications.	Implement RBAC with server-side authorization checks, input validation, horizontal/vertical access control testing, and periodic privilege audits.

5. Security Controls Implemented

The system integrates multiple complementary controls to reduce risk across the STRIDE categories. Role-Based Access Control (RBAC) enforces separation of duties and restricts actions by role, mitigating Spoofing, Information Disclosure, and Elevation of Privilege threats. Complaint payloads are encrypted with AES-256 (authenticated modes) to protect confidentiality and integrity of stored sensitive data. Passwords are derived with bcrypt to resist online and offline cracking, reducing Spoofing risk. Transport Layer Security (HTTPS/TLS) protects confidentiality and integrity in transit. Secure session cookies (Secure, HttpOnly, SameSite) and short session lifetimes reduce session hijacking risk. Parameterized SQL queries eliminate a class of injection vulnerabilities that can enable Tampering and Information Disclosure. Audit logging records critical actions and system events to support non-repudiation and forensic analysis. Monitoring and alerting detect anomalous patterns indicative of DoS or privilege escalation attempts.

Each control is selected to map directly to threats identified in the STRIDE analysis: encryption and RBAC protect against information disclosure and tampering; bcrypt and MFA mitigate spoofing; parameterized queries and server-side validation address tampering and injection; logging and signatures reduce repudiation; and infrastructure protections plus rate-limiting address denial-of-service.

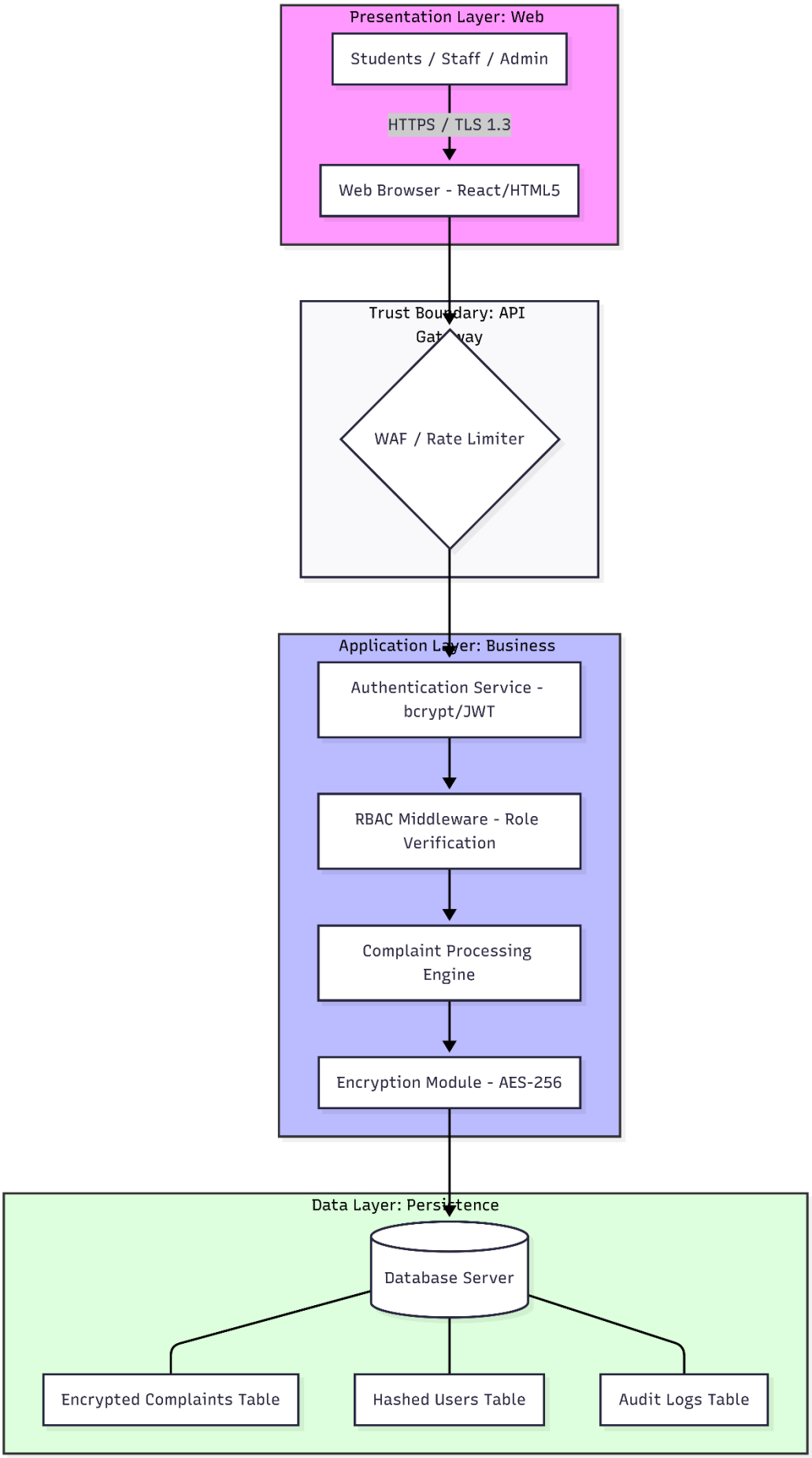
6. Protection of Sensitive Complaint Information

Sensitive complaint information is protected through a layered strategy. Data encryption (AES-256 with authenticated modes) ensures confidentiality at rest and integrity against tampering. Secure authentication (bcrypt plus MFA) ensures only licensed actors can access functionality. Access control policies implemented via RBAC restrict view and modification privileges to appropriate roles; administrative operations require additional checks and logging. All communication channels use TLS to guarantee secure transmission. Activity logging records access, modification, and administrative actions to create an evidentiary trail. Input validation and output encoding prevent injection and cross-site scripting that could expose data to unauthorized parties.

Collectively these measures provide the classical security goals: confidentiality through encryption and access control, integrity through authenticated encryption and parameterized queries, and availability through defensive infrastructure and operational resilience measures.

7. Conclusion

Threat modeling is a disciplined instrument for identifying and mitigating system vulnerabilities prior to deployment. The STRIDE framework provides structured coverage across identity, integrity, confidentiality, availability, and authorization dimensions. For the Encrypted Smart Complaint Management System, the combination of architectural separation, cryptographic protections (AES-256, bcrypt), RBAC, secure transport (TLS), parameterized queries, and robust logging substantially reduces the attack surface and increases the system’s assurance against realistic adversaries. Continued iteration of the threat model alongside code changes, testing, and operational monitoring is recommended to sustain security over the system lifecycle.


Presentation Layer: Web
Students / Staff / Admin
HTTPS / TLS 1.3
Web Browser - React/HTML5
Trust Boundary: API Gateway
WAF / Rate Limiter
Application Layer: Business
Authentication Service - bcrypt/JWT
RBAC Middleware - Role Verification
Complaint Processing Engine
Encryption Module - AES-256
Data Layer: Persistence
Database Server
Encrypted Complaints Table
Hashed Users Table
Audit Logs Table